



MUCHANGI & ASSOCIATES

Advocates · Data Protection & Technology Law

PRACTICE NOTE SERIES

KPLR / PN / 006 / 2026

Data Protection Compliance for AI Integration, Orchestration & Agent Platforms

A working guide to registration, cross-border transfer, and governance for businesses building the connective layer between AI assistants and enterprise systems.



AI GOVERNANCE · DATA PROTECTION · CROSS-BORDER TRANSFER · MCP & AGENTIC SYSTEMS

AUTHOR

Patrick Muchangi

PUBLISHED

September 2026

SERIES

Kenya Privacy Law Review

KENYA PRIVACY LAW REVIEW · PRACTICE NOTE SERIES

Data Protection Compliance for AI Integration, Orchestration & Agent Platforms

A working guide to registration, cross-border data transfer, and governance for businesses building the connective layer between AI assistants and enterprise systems.

PUBLICATION DETAILS

REFERENCE

KPLR/PN/006/2026

EDITION

First Edition · Version 1.0

PUBLISHED

September 2026

AUTHOR

Patrick Muchangi, Advocate of the High Court of Kenya

PRACTICE AREAS

Data Protection · AI Governance · Cross-Border Regulatory Compliance

JURISDICTION

Kenya

SPEAK TO THE FIRM

CALL

0722 878 607

WHATS APP

0736 358 938

EMAIL

consult@dataprivacyadvocates.co.ke

WEBSITE

dataprivacyadvocates.co.ke

.....

This Practice Note is published as a free client-education resource by Muchangi & Associates Advocates. For advice on your own facts, contact the firm directly.

Copyright © 2026 Muchangi Patrick & Associates Advocates. All rights reserved. This publication is for general informational purposes only and does not constitute legal advice.

IN THIS PRACTICE NOTE

1. Who Should Read This Note
2. The Legal Framework at a Glance
3. Step One — Work Out What You Actually Are
4. Step Two — Registration: Do You Need To, and How
5. Step Three — Map Your Data Flows: the Three-Leg Model
6. Step Four — Get Your Public-Facing Documents Right
7. Step Five — Governance for AI & Agentic Architectures
8. Bespoke Integrations Need Their Own Gate
9. Practical Pre-Registration Checklist

AT A GLANCE

- ♦ If your platform processes any personal data passing through it, you very likely need to register with the ODPC — often **twice**, as both controller and processor.
- ♦ Cross-border transfer is rarely one question. Most AI-integration platforms have **three separate transfer legs**, not one.
- ♦ A Privacy Policy drafted before your architecture was finalised is one of the most common sources of real legal exposure we see.
- ♦ Automated allow/block decisions can, in the wrong circumstances, engage section 35 of the Act.
- ♦ Using your own operational data to improve your product can silently convert you from processor to controller.

01 Who Should Read This Note

Over the past year we have advised a growing number of Kenyan and Africa-facing technology businesses that do not fit neatly into the categories most founders think of when they hear "data protection law." They are not banks, hospitals, or telcos. They describe themselves as "just infrastructure," "just an API layer," or "just plumbing between AI tools and business systems." Typical examples include:

- **AI integration and access-gateway platforms** — governed middleware that connects AI assistants (Microsoft Copilot, ChatGPT, Claude, Gemini and others) to a business's internal systems, using an open protocol such as the Model Context Protocol (MCP) or a similar tool-calling standard;
- **Agent orchestration layers** — platforms that route, authenticate, and log the actions an AI agent takes across multiple connected systems on a user's behalf;
- **Retrieval-augmented generation (RAG) and vector-database intermediaries** — infrastructure that indexes and serves an organisation's own documents and records to an AI model;
- **AI-powered workflow and automation tools** — products that use a third-party foundation model under the hood to process customer data and trigger actions in other systems.

If your business fits any of these descriptions, this note is for you. Its central message is simple: **you are very likely a data controller, a data processor, or both, under the Data Protection Act, 2019 — whether or not you think of yourself as an "AI company" or a "data company."** Kenya does not yet have AI-specific legislation. Until it does, the Data Protection Act, 2019 ("the Act") and its regulations are the primary binding legal framework governing what your platform does with personal data, and non-compliance carries real financial, criminal and reputational exposure.

02 The Legal Framework at a Glance

Kenya's data protection regime rests on:

- The **Data Protection Act, 2019** (No. 24 of 2019) — the primary statute, establishing the ODPC, the registration regime, the data protection principles, data subject rights, the rules on sensitive personal data, and the cross-border transfer regime.
- The **Data Protection (Registration of Data Controllers and Data Processors) Regulations, 2021** — the registration thresholds, tiers and fees.
- The **Data Protection (General) Regulations, 2021** — detailed rules on consent, data subject rights, cross-border transfer safeguards, and security.
- The **Data Protection (Complaints Handling Procedure and Enforcement) Regulations, 2021**.
- **ODPC Guidance Notes**, including guidance on registration and, more recently, on cross-border data transfer, which give practical texture to the statutory conditions.

None of this is AI-specific. It applies to *any* processing of personal data by automated or non-automated means, by a controller or processor established in Kenya, or processing personal data of data subjects located in Kenya even if the processor is based elsewhere. An AI assistant, an LLM-powered workflow tool, or an MCP-based integration gateway is, from the Act's perspective, simply a system that processes personal data — often at higher volume, higher speed, and with more automated judgment than the software that came before it, which is precisely why the existing rules bite harder, not less, on this category of business.

03 Step One — Work Out What You Actually Are

Before anything else, characterise your own role correctly. This drives almost every other answer in this note.

Controller or processor? A *data controller* determines the purposes and means of processing. A *data processor* processes personal data on the controller's behalf and instructions. Most AI-integration platforms are, in practice, **both**: a processor in respect of the customer data flowing through the platform on behalf of each enterprise customer, and a controller in their own right for their own website visitors, registered users, billing records, and staff.



Figure 1 — Establishing your role before anything else follows from it.

This matters because registration, contractual obligations, and liability exposure differ by role, and because most platforms need to register twice, not once. Within the "processor" role, be precise about what you are actually doing, because the answer is rarely a single, simple thing. We find it useful to separate three distinct layers of activity that are easy to conflate:

1. **Tool or connector orchestration** — deciding which downstream connector executes a given request, authenticating and authorising it, and logging it. This is core to almost every platform in this category and is a real, if comparatively low-footprint, form of processing.
2. **Reasoning or sequencing orchestration** — deciding *which* tools to call, in what order, to answer a broader question. In most current AI-assistant architectures this decision sits with the connecting AI assistant or agent itself, not the integration layer — but do not assume this without checking your own build.
3. **Computation on your own infrastructure** — aggregating, filtering, matching, or otherwise transforming the underlying data before returning a result. Even simple aggregation performed on your own servers is genuine processing, not passive relay. Cross-system matching or reconciliation — combining data from two or more of a customer's connected systems inside a single operation — is a materially bigger step again, and deserves its own, specific risk assessment.

SELF-TEST

Does any component of your own system decide *which* backend systems to query, independent of an instruction? Does any component *compute* a result rather than simply relaying one? Does your system ever *combine* data from two or more of a customer's own systems in a way the customer did not explicitly request in that form? A "yes" to any of these means your processing footprint is larger than a pure access-governance description would suggest.

04 Step Two — Registration: Do You Need To, and How

The legal duty. Section 18 of the Act provides that no person shall act as a data controller or data processor unless registered with the Data Commissioner, subject to thresholds the Commissioner prescribes by reference to the nature of the industry, the volume of data processed, whether sensitive personal data is involved, and any other criteria specified.

Thresholds and exemption. Under the Registration Regulations, a private-sector entity is exempt from mandatory registration only where it satisfies **both** of the following at the same time: annual turnover below KES 5,000,000, and fewer than 10 employees. Meeting only one condition is not enough. The exemption also never applies, regardless of size, to a defined list of sectors — including financial services, telecommunications, health administration, direct marketing, education, and property management, among others. Many AI-integration businesses assume the small-company exemption protects them without checking this second condition — and a platform whose core function is to broker access to financial, health, or communications data for its customers may be found to sit within one of these carved-out sectors even though it is not itself a bank, hospital, or telco. Where this is genuinely arguable rather than clear-cut, the safer and, in most cases, cheaper course is simply to register.

FEE TIERS — PRIVATE SECTOR

CATEGORY	REGISTRATION FEE (ONCE)	RENEWAL FEE (24 MONTHS)
Micro & small — 1–50 employees, turnover up to KES 5 million	KES 4,000	KES 2,000
Medium — 51–99 employees, turnover KES 5m–50m	KES 16,000	KES 9,000

CATEGORY	REGISTRATION FEE (ONCE)	RENEWAL FEE (24 MONTHS)
Large — over 99 employees, turnover above KES 50 million	KES 40,000	KES 25,000

A non-exempt mandatory-sector entity below the general threshold is still charged the micro & small rate, since its duty to register arises from sector, not size. Registering as both controller and processor attracts the fee twice.

What the application requires. A registration application must describe the categories of personal data processed, the purpose of processing, the categories of data subjects, any sensitive personal data and the basis for processing it, details of any transfer of data outside Kenya by destination country, and a general description of the risks, safeguards and security measures in place.

A CANDOUR POINT WORTH STATING PLAINLY

If you are aware of any unresolved gap in your own architecture at the time of application — an incomplete security control, a data-retention inconsistency, or similar — our strong recommendation is to disclose it candidly, with a stated remediation timeline, rather than omit it. An application later shown to have concealed a known issue is a materially worse position than one that disclosed it honestly.

Consequences of proceeding unregistered. Processing without required registration is an offence; where the Act does not prescribe a specific penalty, the general penalty applies — currently a fine of up to KES 3,000,000, imprisonment of up to ten years, or both. Separately, the ODPC's administrative fine power allows a penalty of up to KES 5,000,000, or a percentage of the undertaking's preceding year's turnover, for substantive breaches — a power the ODPC has exercised against a number of Kenyan businesses in recent years, including in the technology and financial-services space.

05 Step Three — Map Your Data Flows: the Three-Leg Model

This is, in our experience, the single area where AI-integration businesses most consistently under-scope their own compliance work. Founders tend to think of cross-border transfer as a single question — "where is our server?" — when an AI-integration platform typically has **at least three analytically distinct transfer legs**, each requiring its own safeguards analysis under sections 48–50 of the Act and the ODPC's Guidance Note on Cross-Border Data Transfer.

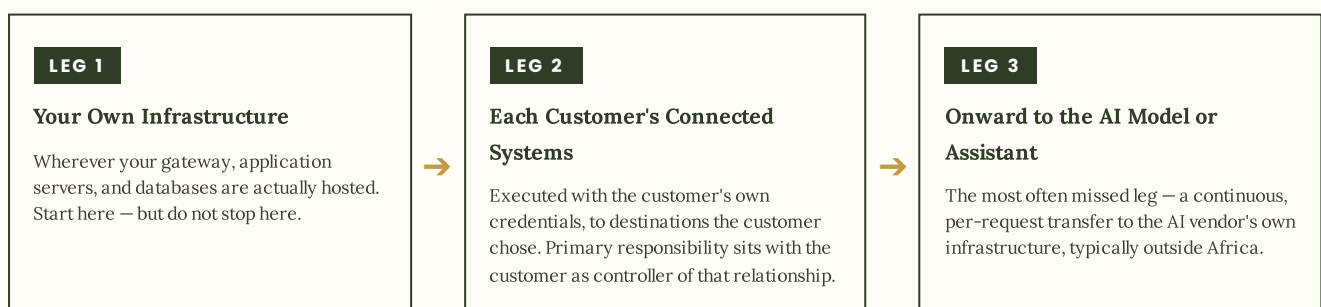


Figure 2 — The three-leg cross-border transfer model for AI-integration platforms.

ILLUSTRATIVE EXAMPLE

Consider a platform that connects enterprise AI assistants to a customer's finance, tax, and CRM systems. Its own servers are hosted on a well-known cloud provider in a country outside Kenya. Its customers' own connected systems – payment processors, tax authority portals, CRM platforms – sit in still other locations, some in Kenya, some not, all chosen by the customer. And every time the platform answers a query, it sends the processed result to whichever AI assistant the customer has connected – an assistant whose infrastructure sits in yet another jurisdiction again. Three legs. Three separate questions. One privacy policy, if drafted carelessly, might address none of them properly, or might address only the first and assume the job is done.

Leg 3 deserves particular attention, for two reasons. **Onward-use restrictions** – ODPC guidance treats onward transfer for a recipient's own analytics, product-improvement, or marketing purposes as strictly restricted. Many consumer AI tools use submitted content to improve their own models by default; most (not all) enterprise or API tiers exclude this – confirm the specific terms in writing, for the specific tier, for every vendor you support. **Available safeguards vary by destination** – an adequacy decision, ratification of the African Union's Malabo Convention by the destination country, a documented appropriate-safeguards assessment, or a necessity ground will differ by vendor infrastructure location; do not assume a "deemed safeguard" route applies without checking the destination country's actual treaty status.

Practical recommendation. Build and maintain a Transfer Impact Assessment that separately addresses all three legs. Maintain a running register of every sub-processor and connected AI vendor, the data each receives, the legal basis relied upon, and the destination's safeguard status – a living document, updated whenever a new connector or AI vendor integration is added.

A NOTE ON HYPERSCALE CLOUD PROVIDERS

Choosing a cloud infrastructure provider – AWS, Microsoft Azure, Google Cloud – is a legal decision, not only a technical one. Three points are worth stating plainly. **First**, the shared-responsibility model these providers operate on means the provider secures the underlying infrastructure, but you remain responsible for how you configure it – a misconfigured storage bucket is your failure under the Act's security-safeguards requirements, however reputable the platform. **Second**, where any data falls within the Act's narrow definition of sensitive personal data, the heightened rule applies regardless of how secure the hosting is in general terms: such data may only leave Kenya with both the data subject's consent and confirmation of appropriate safeguards, and a general certification assurance does not, on its own, satisfy the consent limb. **Third**, and most often overlooked: AWS, Microsoft and Google are all United States-headquartered entities, and US law (the CLOUD Act, 2018) permits US authorities to compel production of data in a US provider's possession, custody, or control regardless of where it is physically stored. A non-US data-centre region reduces certain risks but does not, by itself, remove this exposure, and should not be represented to customers or the regulator as though it does.

06 Step Four – Get Your Public-Facing Documents Right

We repeatedly see the same handful of errors in Privacy Policies and Terms of Use published by businesses in this space, often because the documents were adapted from a generic template, or drafted before the underlying architecture was finalised, and never revisited once the product changed.

- **Incorrect citation of the lawful bases for processing.** The Act sets out a specific, structured list (consent; and, under a single further paragraph, a range of "necessity" grounds including contract performance, legal obligation, vital interests, and legitimate interests). We regularly see these mis-cited or transposed. Check this against the primary text of the Act itself, not a template that may already contain the error.
- **Overuse of "vital interest" as a catch-all.** This basis is narrow and, on ODPC guidance, effectively limited to matters of life and death. It is not an appropriate basis for routine security monitoring or fraud prevention, which are far better supported by legitimate interest or legal obligation.
- **A mismatch between how a feature is described and how it actually works.** There is commercial pressure to describe a feature as "AI-powered" or as performing "analysis" when the underlying mechanism is, in fact, simpler. This is not merely a marketing question — whichever direction the error runs, it is a transparency problem, and should be resolved by asking engineering a specific, direct question, not by inference from marketing copy.
- **Incomplete sub-processor and infrastructure disclosure.** A common gap: two cloud providers are genuinely in use, and the published table only ever reflects the first added.
- **Retention periods that do not match system behaviour — and a fix that can run in either direction.** The instinctive fix is to lower the published figure to match the system default. That is not always right — if customers have their own sector-specific record-keeping obligations (anti-money-laundering record-keeping commonly runs to several years under Kenyan law), a short system default that does not support those needs may be the thing that actually needs to change.
- **Absolute claims about system guarantees.** Particular caution is warranted around unqualified language such as "can never" or "always" in relation to security or isolation guarantees — these age badly and are the first thing scrutinised in any subsequent investigation.
- **Marketing claims about data location that do not survive a full data-flow audit.** Claims such as "your data never leaves [a given region]" very often do not survive the full three-leg picture once the onward transfer to an AI vendor is taken into account.

07 Step Five — Governance for AI & Agentic Architectures

A handful of provisions in the Act deserve specific, deliberate attention for this category of business, precisely because AI-driven and agentic systems are more likely than traditional software to trigger them without anyone noticing.

Automated decision-making

The Act gives every data subject a right not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects or significantly affects them. Access-control and security-gating decisions will generally sit outside this right, being closer to routine IT permissioning than to a decision about an individual's own entitlements — but this changes where an automated block or approval determines whether a specific customer or data subject actually receives a benefit, payment, or service.

The "deemed controller" trap

Where a processor processes personal data other than as instructed by the controller, the Act deems the processor to be a controller for that specific processing. This is a real and growing risk for AI-infrastructure businesses, because operational data flowing through such a platform — logs, usage patterns, flagged or blocked requests — is exactly the kind of data a technical team is tempted to use to improve its own product, tune its own detection systems, or build its own analytics, independently of any customer instruction to do so. Treat any such use as a distinct processing activity requiring its own lawful basis and its own disclosure.

Breach-notification duties differ by role, and are commonly conflated

A controller's duty is to notify the regulator within 72 hours of becoming aware of a qualifying breach. A processor's duty is different and shorter: to notify the *controller* — not the regulator directly — within 48 hours. If you are the processor, your own direct statutory duty is the 48-hour notice to your customer; your customer then carries the 72-hour duty to the regulator. Build an internal notification commitment meaningfully shorter than 48 hours into customer contracts.

Processor liability is narrower than controller liability — until it isn't

A data subject's statutory compensation right runs against a controller for any damage caused by processing, but against a processor only where it has failed to comply with an obligation specifically directed at processors, or has acted outside or contrary to the controller's lawful instructions. This is precisely why the "deemed controller" point above matters: stepping outside instructions is the event that converts narrower processor exposure into full controller-level exposure.

Data Protection Officer designation

The Act frames DPO designation as discretionary in most cases, but treats it as effectively necessary where an organisation's core activities require regular and systematic monitoring of data subjects. A platform whose core function is continuous, automated logging and governance of data flows is a strong candidate for this trigger, regardless of company size.

Children's data, and precision on "sensitive personal data"

Where a child's data could pass through your platform, even incidentally, the Act requires appropriate mechanisms for age verification and consent, not merely a policy statement that the service is not intended for minors — for a B2B platform, a contractual warranty from the customer is usually a more proportionate answer than a technical age gate. Separately, the Act defines "sensitive personal data" narrowly and specifically; financial and tax data, however commercially sensitive, does not automatically fall within this legal definition. Use "high-risk" for the commercial sense, and reserve the legal term for the legal category.

08 Bespoke Integrations Need Their Own Gate

Standard product features can be assessed once, at a general level. Custom, bespoke connectors or integrations built for a single customer cannot be — each one is, by definition, a different technical arrangement, potentially with a different data-flow and risk profile, including a materially

higher chance of cross-system data matching or automated decisioning that the general assessment never contemplated.

RECOMMENDATION

Adopt a standing internal policy requiring a short, mandatory data-flow and risk review before any bespoke connector or integration is built or sold — applied every time, rather than relying on a general compliance assessment of the base product to cover work that, by its nature, keeps changing.

09 Practical Pre-Registration Checklist

- ☒ Confirm your correct, currently registered legal entity name and company number, and check every published legal document actually uses it.
- ☒ Confirm whether you need to register as controller, processor, or both — in almost every case for this category of business, the answer is both.
- ☒ Confirm your turnover and headcount, and your correct registration fee tier.
- ☒ Consider, and document, whether any mandatory-sector carve-out could apply regardless of size — and if genuinely unclear, register anyway.
- ☒ Map all three cross-border transfer legs separately — your own infrastructure, each customer's connected systems, and the onward transfer to any AI vendor.
- ☒ Confirm the specific data-use and training-exclusion terms of every AI vendor you connect, for the specific tier through which you connect them, in writing.
- ☒ Confirm every cloud provider and sub-processor you actually use today is reflected in your published disclosures.
- ☒ Document your cloud provider's shared-responsibility boundary, your own security configuration, and your key-management model as a specific line item in your Transfer Impact Assessment.
- ☒ Where the provider is US-headquartered, document the CLOUD Act exposure separately, and avoid representing a non-US region as removing it.
- ☒ Re-check every lawful-basis citation in your Privacy Policy against the primary text of the Act.
- ☒ Confirm your published retention periods match what your system actually implements — and check whether any customer's own sector-specific obligations should change the system, not just the policy.
- ☒ Confirm whether any operational data is, or will be, used for your own purposes, and treat that as a separate processing activity if so.
- ☒ Confirm processor breach-notification commitments to customers are meaningfully shorter than the statutory 48-hour window.
- ☒ Designate a Data Protection Officer and notify the ODPC, rather than treating this as optional.
- ☒ Put a written data processing agreement in place with every customer, addressing responsibility for each transfer leg.
- ☒ Adopt a standing internal policy requiring a data-flow and risk review before any bespoke integration is built.

KEY TAKEAWAYS

- Kenya has no AI-specific statute yet — the Data Protection Act, 2019 is the binding framework for AI-integration platforms today, and applies with full force.
- Most platforms in this category are both controller and processor, and must register, and pay, twice.
- Cross-border transfer is a three-leg question — your own hosting, your customers' connected systems, and the onward transfer to the AI vendor itself — not a single hosting-location question.
- Privacy documentation drafted before the architecture was finalised is a recurring, material source of exposure — get it re-checked against what the system actually does, not what it was originally intended to do.
- Using your own platform's operational data for your own purposes can convert you into a controller for that processing, with a fresh set of obligations.
- Bespoke, customer-specific integrations need their own governance gate — a general assessment of the standard product does not cover them.

How We Can Help. We advise founders and technical teams building AI integration, orchestration, and agentic infrastructure on exactly the issues in this note — from first ODPC registration through to cross-border transfer assessments, privacy documentation, and ongoing Data Protection Officer support. If any part of this note describes your business, we would be glad to talk it through with you.

CALL THE FIRM

0722 878 607

WHATSAAPP

0736 358 938

ONLINE

dataprivacyadvocates.co.ke**MUCHANGI PATRICK**

Advocate of the High Court of Kenya · Data Protection, AI Governance & Cross-Border Regulatory Practice · Muchangi & Associates Advocates

RECOMMENDED CITATION

Muchangi & Associates Advocates, "Data Protection Compliance for AI Integration, Orchestration and Agent Platforms Operating in or from Kenya", Practice Note No. 006, KPLR/PN/006/2026 (September 2026).

This Practice Note is for guidance purposes only and does not constitute legal advice. It describes general, abstract patterns we have observed across a category of business model and is not based on, and does not describe, any specific client or engagement. Data controllers and processors should seek independent legal advice on their own specific facts, and should confirm current fees and procedural detail on the ODPC portal before relying on them. © 2026 Muchangi & Associates Advocates. All rights reserved.